PROTEXXA CYBER NATIONS SCOTIARISE CYBER SECURITY ANALYST PROGRAM CAPSTONE PROJECT: CYBERSECURITY POLICY

CYBER SECURITY POLICY



Zolian R. Smith
October 1, 2025

Table of Contents

CYBERSECURITY POLICY 3
1. Introduction & Background 3
2. Password Management 3
3. Employee Cybersecurity Training 5
4. Data Protection 6
5. Incident Response 8
6. Network Security 9
7. Remote Work Security 11
8. Policy Enforcement 12
FRAMEWORK ALIGNMENT 14
EMPLOYEE AWARENESS GUIDE 17
REFERENCES 21
APPENDICES 22

CYBERSECURITY POLICY

1. Introduction & Background

Purpose: This Cybersecurity Policy establishes the security standards and practices necessary to protect our company's information assets, technology infrastructure, and business operations from cyber threats. The policy aims to minimize security risks, ensure business continuity, and maintain the trust of our customers and partners.

Applicability: This policy applies to all employees, contractors, temporary staff, interns, and third-party vendors who access company systems, networks, or data. All individuals covered by this policy must read, understand, and comply with these requirements as a condition of system access and continued employment or engagement with the organization.

2. Password Management

Password Complexity Requirements:

- All passwords must be at least 12 characters in length
- Passwords must contain a combination of uppercase letters, lowercase letters, numbers, and special characters
- Passwords must not contain dictionary words, personal information, or common patterns
- Passwords must be unique for each system and must not be reused across multiple accounts

Multi-Factor Authentication (MFA):

- MFA is required for all email accounts, remote access systems, and any application containing sensitive company or customer data
- MFA methods include authenticator apps, SMS codes, or hardware tokens
- Users must register at least two MFA methods to prevent account lockout

Password Update Frequency:

- Passwords must be changed every 90 days for all systems
- Immediate password changes are required if a password is suspected to be compromised or if an employee leaves the company
- Employees will receive automated reminders 14 days before password expiration

Password Managers:

- Company-approved password managers are strongly encouraged and may be provided by IT
- Password managers help employees create and store strong, unique passwords securely
- Employees must enable MFA on their password manager accounts
- Sharing passwords through email, text messages, or written notes is strictly prohibited

3. Employee Cybersecurity Training

Training Frequency:

- All employees must complete mandatory cybersecurity awareness training quarterly (every three months)
- New employees must complete initial security training within the first week of employment
- Additional training sessions will be conducted immediately following any security incident

Topics Covered:

- Identifying and reporting phishing emails and social engineering attempts
- Secure password practices and proper use of MFA
- Safe browsing habits and avoiding malicious websites
- Secure file sharing and proper handling of sensitive information
- Physical security practices including device protection and clean desk policies
- Social media security and protecting company information online
- Mobile device security and safe app downloads
- Recognizing ransomware and malware threats

Reporting Suspicious Activity:

- Employees must immediately report any suspicious emails, phone calls, or activities to the IT Department or their immediate supervisor
- Do not click on suspicious links, download unknown attachments, or provide sensitive information to unverified requesters
- Report lost or stolen devices within one hour of discovery
- Use the Security Incident Report Form available on the company intranet or email security@TechFlowSolutions.com
- There will be no negative consequences for reporting potential security concerns in good faith

4. Data Protection

Data Storage and Protection:

- All sensitive company data must be stored on company-approved servers, cloud storage, or encrypted databases
- Sensitive data includes customer information, financial records, employee personal information, trade secrets, and proprietary business information
- Personal devices and unsecured cloud services may not be used to store company data
- Access to sensitive data is granted on a need-to-know basis and requires manager approval

Encryption Requirements:

- All laptops and mobile devices containing company data must have full-disk encryption enabled
- Sensitive files transmitted via email or file-sharing services must be encrypted or password-protected
- All remote connections to company systems must use encrypted protocols (VPN, HTTPS, SSH)
- Encryption keys and passwords must be stored securely and never transmitted with the encrypted files

File Sharing and Removable Media:

- Use only company-approved file sharing services for transmitting business files
- USB drives and external hard drives must be company-issued, encrypted, and scanned for malware before use
- Personal USB drives are prohibited from connecting to company computers
- Verify recipient information carefully before sharing sensitive documents
- Set expiration dates and access controls on shared files when possible

Backup and Data Retention:

- Critical business data is automatically backed up daily to secure, off-site locations
- Backups are retained for 90 days, with monthly backups retained for one year

- Employees are responsible for ensuring their work is saved to backed-up company locations
- Data deletion requests must follow legal and regulatory retention requirements
- Departed employee data will be retained for 12 months before secure deletion

5. Incident Response

What to Do If You Suspect an Incident:

- Immediately disconnect the affected device from the network (unplug Ethernet cable or disable Wi-Fi)
- Do not turn off the device, as this may destroy evidence needed for investigation
- Do not attempt to investigate or fix the problem yourself
- Report the incident immediately using the methods described below
- Document what you observed, including any error messages, suspicious emails, or unusual behavior

Who to Contact:

- Primary Contact: IT Department at security@TechFlowSolutions.com or extension 1234
- After Hours: Emergency Security Hotline at 555-0100
- Your Direct Supervisor or Department Manager
- For urgent matters, contact the Chief Information Security Officer (CISO) directly

Quick Response Steps:

1. Stop what you are doing and assess the situation
2. Disconnect the affected device from the network immediately
3. Contact IT or the Security Team right away
4. Do not delete anything or attempt to clean up files
5. Preserve any evidence such as suspicious emails or screenshots
6. Write down a timeline of events while details are fresh
7. Follow all instructions provided by the security response team
8. Do not discuss the incident publicly or on social media

Remember: Rapid reporting is critical. Time is the most important factor in containing security incidents and preventing data loss.

6. Network Security

Firewall and Antivirus Protection:

- All company computers must have approved antivirus software installed and actively running
- Antivirus definitions must be updated automatically daily
- Employees must not disable, uninstall, or tamper with security software
- Firewalls must be enabled on all devices accessing the company network
- Regular vulnerability scans will be conducted by IT to identify security weaknesses

Wi-Fi Security:

- Company Wi-Fi: Used for business devices and requires authentication with company credentials
- Guest Wi-Fi: Available for visitors and personal devices, with restricted access to company resources
- The company Wi-Fi password must not be shared with unauthorized individuals
- Employees must never connect to unknown or unsecured Wi-Fi networks with company devices
- Wi-Fi networks named similarly to the company network may be malicious and should be reported

Device Access Rules:

- Personal devices may connect only to the Guest Wi-Fi network, not the business network
- Company-owned devices must be registered with IT before network access is granted
- All devices must meet minimum security standards including up-to-date operating systems and security software
- IoT devices (smart speakers, cameras, etc.) require IT approval before connecting to any company network
- Unauthorized network devices will be automatically disconnected and investigated

7. Remote Work Security

Secure Remote Access:

- All remote access to company systems must occur through the company VPN
- VPN connections require both password authentication and MFA
- Never access company resources over unsecured public Wi-Fi without VPN protection
- Remote desktop software must be company-approved and properly configured by IT
- Keep remote access credentials confidential and never share login information

Approved Devices:

- Only company-issued or IT-approved devices may be used to access company systems remotely
- Personal computers require IT security assessment and approval before use for work purposes
- All remote work devices must meet the same security standards as office devices
- Company devices must not be used by family members or for personal high-risk activities

Public Wi-Fi Precautions:

- Avoid conducting company business on public Wi-Fi networks whenever possible

- If public Wi-Fi must be used, always connect through the company VPN first
- Never access sensitive data or perform financial transactions on public networks
- Be aware of shoulder surfing and ensure your screen is not visible to others
- Consider using a mobile hotspot from your phone as a safer alternative to public Wi-Fi

8. Policy Enforcement

Consequences for Non-Compliance:

- First Violation: Verbal warning and mandatory retraining
- Second Violation: Written warning placed in personnel file and additional security training
- Third Violation: Suspension of system access privileges and potential disciplinary action
- Severe or Intentional Violations: Immediate termination of employment and possible legal action
- Security violations that result in data breaches may result in personal liability

Additional Enforcement Measures:

- Regular audits will be conducted to ensure policy compliance
- Access privileges may be revoked for repeated or serious policy violations
- Contractors and vendors found in violation may have their contracts terminated

- All security incidents will be investigated thoroughly and documented

Policy Acknowledgment:

- All employees must sign an acknowledgment form confirming they have read, understood, and agree to comply with this policy
- Acknowledgment forms will be collected during onboarding and annually thereafter
- Failure to sign the acknowledgment form will result in denial of system access
- Policy updates will be communicated via email, and employees must acknowledge receipt within five business days
- Questions about this policy should be directed to the IT Department or Human Resources

FRAMEWORK ALIGNMENT

NIST Cybersecurity Framework 2.0 Mapping

This Cybersecurity Policy has been aligned with the NIST Cybersecurity Framework 2.0, which provides a comprehensive approach to managing cybersecurity risk. The framework is organized around six core functions: Govern, Identify, Protect, Detect, Respond, and Recover. Our policy addresses each of these functions to create a holistic security posture appropriate for small business operations.

- **Framework Mapping Table**

NIST CSF 2.0 Function	Policy Section Addressing It	Description
GOVERN	Policy Enforcement, Employee Training	Establishes organizational context, cybersecurity strategy, and oversight through policy enforcement mechanisms and mandatory training requirements
IDENTIFY	Data Protection (Data Classification), Network Security (Device Access)	Identifies and documents company assets, data locations, and authorized devices to understand organizational cybersecurity risks

NIST CSF 2.0 Function	Policy Section Addressing It	Description
PROTECT	Password Management, Data Protection (Encryption), Network Security (Firewalls/Antivirus)	Implements safeguards through strong authentication, encryption standards, and protective technologies to secure critical assets
PROTECT	Employee Cybersecurity Training, Remote Work Security	Develops security awareness and implements secure configuration requirements for all access scenarios
DETECT	Incident Response (Reporting Suspicious Activity), Network Security (Vulnerability Scans)	Enables timely discovery of cybersecurity events through employee vigilance and automated monitoring systems
RESPOND	Incident Response (Contact Information, Quick Response Steps)	Establishes response planning and procedures to contain incidents quickly and minimize impact
RECOVER	Data Protection (Backup and Retention), Incident Response	Ensures resilience and restoration capabilities through regular backups and documented recovery procedures

Alignment Explanation

Our Cybersecurity Policy comprehensively addresses the **NIST CSF 2.0 framework** goals by implementing practical controls across all six core functions. The **GOVERN** function is satisfied through clear policy enforcement mechanisms and mandatory training that establish accountability and security culture throughout the organization. The **IDENTIFY** function is addressed by documenting where sensitive data resides and maintaining an inventory of authorized devices accessing company resources.

The **PROTECT** function receives the most extensive coverage through multiple policy sections including password management with MFA requirements, encryption standards for data at rest and in transit, network security controls, and comprehensive remote work security guidelines. These controls work together to create defense-in-depth protection appropriate for small business operations.

The **DETECT** function is primarily addressed through our incident response procedures that encourage immediate reporting of suspicious activities, complemented by automated security tools like antivirus and vulnerability scanning. The **RESPOND** function is clearly defined with specific contact information, escalation procedures, and immediate action steps that employees can follow during security incidents. Finally, the **RECOVER** function is supported by our backup and data retention policies that ensure business continuity and rapid restoration of operations following any security event.

This alignment demonstrates that our policy is not merely a collection of rules, but rather a strategic security framework that follows industry best practices and can scale as our organization grows.

EMPLOYEE AWARENESS GUIDE

- **CYBER SECURITY ESSENTIALS: YOUR QUICK REFERENCE GUIDE**

🔐 STRONG PASSWORDS SAVE THE DAY

- **CREATE:** 12+ characters with uppercase, lowercase, numbers, and symbols
- **PROTECT:** Never share passwords or write them down
- **MULTIPLY:** Use different passwords for each account
- **SECURE:** Enable Multi-Factor Authentication (MFA) everywhere
- **MANAGE:** Use a company-approved password manager
- 🎣 **SPOT THE PHISH: Don't Take the Bait!**

WARNING SIGNS:

- Urgent requests for passwords or personal information
- Suspicious sender addresses (check carefully!)
- Poor grammar or spelling errors
- Unexpected attachments or links
- Too good to be true offers

WHEN IN DOUBT: Don't click! Report it to security@TechFlowSolutions.com

🚨 CYBER EMERGENCY? ACT FAST!

IF YOU SUSPECT AN INCIDENT:

1. **DISCONNECT** the device from network immediately
2. **DON'T** turn off the device
3. **CALL** IT at ext. 1234 or security@TechFlowSolutions.com
4. **PRESERVE** evidence (don't delete anything)
5. **DOCUMENT** what happened

Remember: Quick reporting limits damage!

💼 PROTECT COMPANY DATA LIKE YOUR OWN

- Store sensitive data only on approved company systems
- Encrypt files before sharing externally
- Lock your computer when you step away (Windows + L)
- Never use personal USB drives on work computers
- Shred confidential documents before disposal

🏠 WORKING REMOTELY? STAY SECURE!

- Always connect through company VPN
- Avoid public Wi-Fi or use VPN if necessary

- Keep work devices for work only
- Update software when prompted
- Secure your home workspace

🛡️ WHY THIS MATTERS TO YOU

FOR THE BUSINESS:

- Data breaches cost an average of $4.45 million
- One successful attack can shut down operations for days
- Customer trust takes years to build, seconds to destroy

FOR YOU:

- Protects your job and livelihood
- Safeguards your personal information
- Prevents identity theft
- Maintains customer relationships
- Ensures you get paid on time

📞 NEED HELP? WE'RE HERE!

IT Department: security@TechFlowSolutions.com | Ext. 1234 **Emergency Hotline:** 555-6789 (24/7) **Security Training:** Available quarterly

REMEMBER: Cybersecurity is EVERYONE'S responsibility. You are our first line of defense!

When you see something suspicious, say something immediately. No question is too small, and no concern is too minor.

REFERENCES

1. National Institute of Standards and Technology (NIST). (2024). NIST Cybersecurity Framework 2.0. Retrieved from https://www.nist.gov/cyberframework

2. Verizon. (2024). Data Breach Investigations Report. Retrieved from https://www.verizon.com/business/resources/reports/dbir/

3. Center for Internet Security (CIS). (2024). CIS Controls Version 8. Retrieved from https://www.cisecurity.org/controls

4. International Organization for Standardization. (2022). ISO/IEC 27001:2022 Information Security Management. Retrieved from https://www.iso.org/standard/27001

5. Cybersecurity and Infrastructure Security Agency (CISA). (2024). Security Awareness Best Practices. Retrieved from https://www.cisa.gov/cybersecurity

6. SANS Institute. (2024). Security Awareness Training Resources. Retrieved from https://www.sans.org/security-awareness-training

7. IBM Security. (2024). Cost of a Data Breach Report 2024. Retrieved from https://www.ibm.com/security/data-breach

8. Microsoft. (2024). Remote Work Security Best Practices. Retrieved from https://www.microsoft.com/security

APPENDICES

Appendix A: Security Incident Report Form Template

Date of Report: _____

Time of Incident: _____

Reported By: _____

Department: _____

Type of Incident (check all that apply):

- [ ] Suspicious email/phishing attempt
- [ ] Lost or stolen device
- [ ] Unauthorized access attempt
- [ ] Malware or virus detection
- [ ] Data breach or leak
- [ ] Other: _____

Description of Incident:

_____

_____

_____

Actions Taken:

Witness Information (if applicable):

Signature: _____

Appendix B: Password Policy Quick Reference Card

MINIMUM REQUIREMENTS:

- Length: 12+ characters
- Complexity: Mix of upper, lower, numbers, symbols
- Uniqueness: Different for every account
- MFA: Required for all critical systems

CHANGE FREQUENCY: Every 90 days

NEVER:

- Share passwords
- Write them down
- Reuse passwords
- Use personal information

ALWAYS:

- Use password manager
- Enable MFA
- Report suspicious activity

Appendix C: Approved Software and Services List

Password Managers:

- 1Password (Company Provided)
- LastPass Business
- Bitwarden

File Sharing Services:

- Microsoft OneDrive for Business
- Google Drive (Company Account)
- SharePoint

Communication Tools:

- Microsoft Teams
- Zoom (Business Account)
- Company Email Only

VPN Software:

- Company-Issued VPN Client (Required)

Antivirus Software:

- Microsoft Defender (Windows)
- Company-Managed Endpoint Protection

Note: This list is maintained by IT and updated quarterly. Check the company intranet for the most current version.

Appendix D: Policy Acknowledgment Form

CYBERSECURITY POLICY ACKNOWLEDGMENT

I, _____ (print name), acknowledge that I have received, read, and understood the TechFlow Solutions Company Cybersecurity Policy dated October 11, 2025.

I understand that:

- This policy applies to me and my use of company systems and data
- I am required to comply with all provisions of this policy
- Failure to comply may result in disciplinary action up to and including termination
- I am responsible for reporting security incidents and suspicious activities immediately
- I will complete required cybersecurity training on schedule

I agree to abide by this policy and any future updates communicated by the company.

Employee Signature: _____

Date: _____

Department: _____

Supervisor Signature: _____

Date: _____

This form must be completed and submitted to Human Resources within 5 business days of policy distribution.

Appendix E: Emergency Contact Information

SECURITY EMERGENCY CONTACTS

Primary IT Support:

- Email: security@TechFlowSolutionscom
- Phone: Ext. 1234
- Hours: Monday-Friday, 8:00 AM - 6:00 PM

After-Hours Emergency:

- Security Hotline: 555-6789
- Available 24/7/365

Leadership Contacts:

- Chief Information Security Officer (CISO): ciso@TechFlowSolutions.com
- IT Manager: itmanager@TechFlowSolutions.com
- Human Resources: hr@TechFlowSolutions.com

External Resources:

- Local Law Enforcement (Cybercrime Unit): 911
- FBI Cyber Division: ic3.gov
- Identity Theft Resources: identitytheft.gov

Keep this information readily accessible!